

บทที่ 6

การออกแบบ โครงสร้าง และการทำงานของระบบ

6.1 แนวคิด

ไฟร์วอลล์ในปัจจุบันมีหลากหลายชนิด และความสามารถแตกต่างกัน รวมถึงการติดตั้งไฟร์วอลล์ในหลายที่ ทำให้การควบคุมทำได้ยาก เพราะต้องตามไปกำหนดกฎในทุกที่ติดตั้งไฟร์วอลล์ยังมีการติดตั้งมากหนึ่งจุดก็จะยังมีความยุ่งยากมากยิ่งขึ้น ยิ่งในปัจจุบันมีการนิยมใช้งานเพอร์ซันนอลไฟร์วอลล์มากยิ่งขึ้น จึงมีความคิดที่จะมีการเพิ่มความสามารถของการกำหนดกฎการป้องกันจากส่วนกลางเพียงจุดเดียวทำให้ง่ายต่อการควบคุม และ จัดการ

ทั้งในปัจจุบันมีการนำไคเรททอรีเซอร์วิสมาใช้ในองค์กรมากยิ่งขึ้นเพราะมีความง่ายในการควบคุม จัดการ และเก็บข้อมูลของผู้ใช้ อีกทั้งยังมีการพิสูจน์ตน (Authentication) ก่อนที่จะเข้าใช้งานทรัพยากรของระบบ และมีมาตรการ การรักษาความปลอดภัยข้อมูลของระบบที่มีประสิทธิภาพ จึงได้นำคุณสมบัติของ แอ็คทีฟไดเรกทอรีในวินโดวส์ 2000 มาเพิ่มความสามารถเพื่อใช้ในการควบคุมกฎของไฟร์วอลล์ และ ใช้ในการเก็บล็อกลงในฐานข้อมูล จากเครื่องลูกข่ายที่อยู่ในระบบปฏิบัติการวินโดวส์ 2000 ทำให้สามารถควบคุมการทำงานของไฟร์วอลล์ได้ที่จุดศูนย์กลางเพียงจุดเดียว

ซึ่งหากมีการโจมตีเกิดขึ้นนั้นสามารถเก็บผลจากการโจมตีได้ เพื่อรวบรวมเข้าด้วยกันให้สามารถนำมาวิเคราะห์กฎที่จะเพิ่มเข้าไปได้อย่างเหมาะสมทำให้ระบบ มีความปลอดภัยยิ่งขึ้น

จากที่ได้กล่าวมาข้างต้นทำให้เกิดแนวความคิดสร้างไฟร์วอลล์ที่มีความสามารถดังนี้

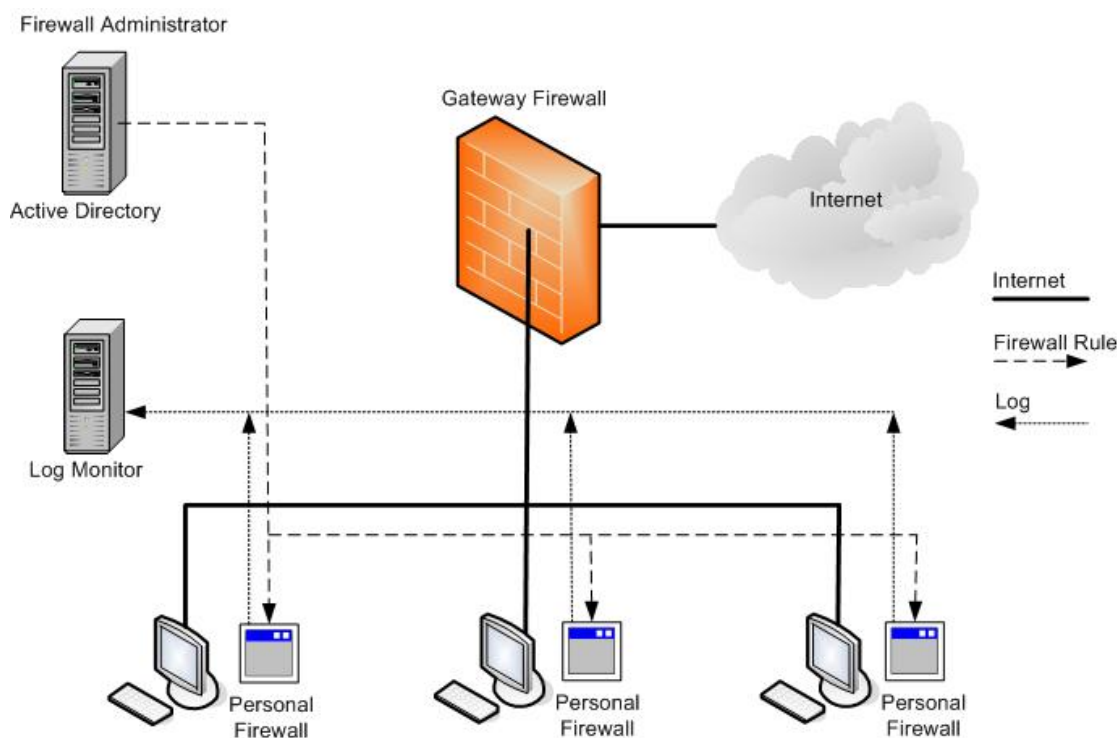
- ไฟร์วอลล์สามารถป้องกันการโจมตีได้ตามกฎ พร้อมทั้งมีระบบตรวจจับผู้บุกรุกทำงานร่วมด้วย
- สามารถกำหนดกฎของไฟร์วอลล์ได้จากส่วนกลาง
- สามารถจัดเก็บการรายละเอียดการโจมตีไว้ที่ฐานข้อมูลกลางได้

สามารถแบ่งโปรแกรมการทำงานออกเป็น 3 ส่วนดังนี้คือ

- Personal Firewall
ออกแบบให้ทำหน้าที่ป้องกันการโจมตีได้ตามกฎที่ได้รับจากเครื่องแม่ข่ายได้อย่างถูกต้อง และเมื่อมีการบุกรุกจะส่งข้อมูลการบุกรุกให้เครื่องโฮสต์มอนิเตอร์
- Firewall Administrator
ออกแบบให้ทำหน้าที่กำหนดกฎการป้องกันในแต่ละกลุ่มผู้ใช้ เพื่อให้ไฟร์วอลล์ในระบบได้รับกฎป้องกันการบุกรุก
- Log Monitor
ออกแบบให้รับรายละเอียดการโจมตีจากเครื่องลูกข่ายที่อยู่ในระบบ และจัดการเกี่ยวกับการนำล็อกไฟล์จากฐานข้อมูลขึ้นมา แสดงผลได้

6.2 โครงสร้างระบบ

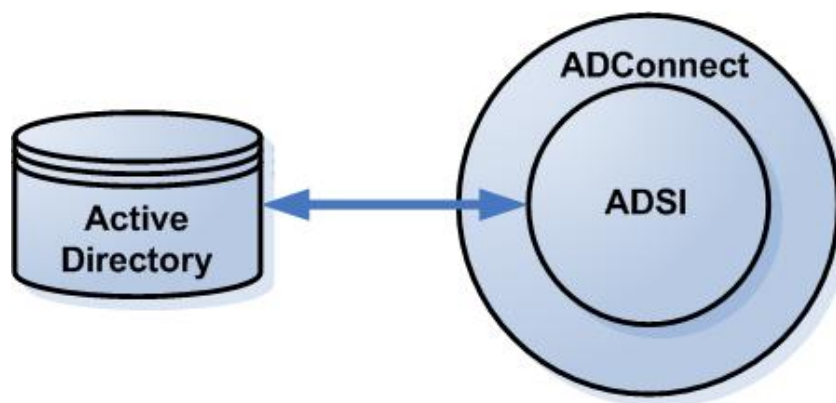
การออกแบบการป้องกันการโจมตีต้องมีการออกแบบการวางระบบให้มีจุดที่เหมาะสม และมีโครงสร้างระบบดังรูปที่ 6-1 โดยนำไฟร์วอลล์ที่ได้ออกแบบมาทำการวางอยู่ในโครงสร้างโดยที่ Firewall Administration กับ Log Monitor จะอยู่ในส่วนของ Server หรือขอบเขตที่ต้องการกันไว้เป็นส่วนที่เข้าถึงได้ยากให้เข้าถึงได้เฉพาะภายในระบบ และส่วนของ Personal Firewall จะติดตั้งในส่วนต่างๆ ของระบบ ส่วน Gateway Firewall จะใช้ความสามารถเหมือนกัน Personal Firewall



รูปที่ 6-1 โครงสร้างและส่วนประกอบหลักของระบบ

6.3 ส่วนประกอบ และ หลักการทำงาน

การติดต่อทุกอย่างในระบบไฟร์วอลล์จะทำงานอยู่บนความสามารถ Active directory ของ Windows 2000 โดยข้อมูลจะเก็บอยู่ใน Active Directory Database และเข้าถึงข้อมูลผ่าน ADSI ไปยัง Active Directory Service เพื่อเข้าถึงข้อมูลที่จัดเก็บ แสดงดังรูปที่ 6-2



รูปที่ 6-2 แสดงรูปแบบการเข้าถึง Active Directory Service

6.3.1 Schema

โครงสร้างของ Active Directory Database ประกอบไปด้วย คอนเทนเนอร์ คลาส และ แอตทริบิวต์ โดยการเข้าถึงข้อมูลเหล่านั้นจะมีการกำหนดหน้าที่การทำงานมาแล้ว ดังนั้นถ้าเราต้องการนำข้อมูลที่เราต้องการจัดเก็บหรือเข้าถึงรูปแบบใหม่เข้าไปจึงต้องมีการสร้างขึ้นใหม่ เพื่อให้เหมาะสมกับการทำงานของระบบ ไดรกทอรี่เบสไฟร์วอลล์

ข้อมูลที่จัดเก็บประกอบด้วย ข้อมูลของกฎและข้อมูลรายละเอียดการโจมตีโดยเพิ่ม Schema ที่เหมาะสมลงไป ใน Active Directory Database ดังนี้

1. แอตทริบิวต์ รายละเอียดการเพิ่มจะเป็นดังตาราง ที่ 6-1

Common Name	OID	Syntax
firewallRule	1.2.840.113556.1.4.7000.142	Case Insensitive String
firewallLog	1.2.840.113556.1.4.7000.144	Case Insensitive String

ตารางที่ 6-1 รายละเอียด Attribute ที่เพิ่มใน Active Directory Database

2. คลาส รายละเอียดการเพิ่มจะเป็นดังตาราง ที่ 6-2

Common Name	OID	Syntax
ISAGFW	1.2.840.113556.1.4.7000.143	Auxiliary

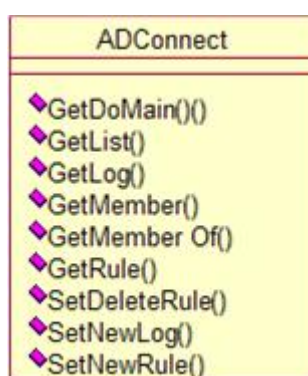
ตารางที่ 6-2 รายละเอียด Class ที่เพิ่มใน Active Directory Database

โดยกำหนดให้ Attribute firewallRule เป็น Mandatory และ FirewallLog จะเป็น Auxiliary ใน class ISAGFW ดังรูปที่ 6-3

3. แผนก Schema ใหม่ เข้ากับ คลาส groups รายละเอียดดังรูปที่ 6-4

6.3.2 ADConnect Class

ในการเข้าถึงข้อมูลที่อยู่ใน Active Directory Service นั้นต้องใช้ ADSI ดังนั้นจึงพัฒนา function ที่ใช้เข้าถึงและกำหนดการทำงานได้อย่างง่ายดายขึ้นมา โดยจะรวมอยู่ใน Class ADConnect จะมีรายละเอียด Function ดังรูปที่ 6-3 โดย Class ADConnect จะใช้ในทุกโปรแกรมที่พัฒนาเพื่อติดต่อ Active Directory Service



รูปที่ 6-3 รายละเอียดของคลาส ADConnect

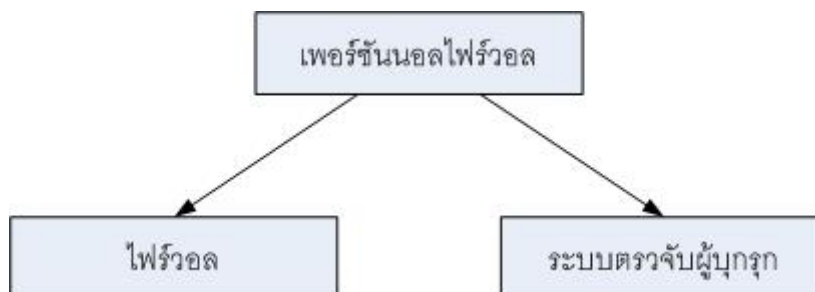
Function	การทำงาน
GetDomain	หาชื่อเครื่องที่ผู้ใช้สังกัดอยู่
GetList	อ่านรายละเอียดที่เป็นจุดอ้างอิง
GetLog	อ่านรายละเอียด Log
GetMember	อ่านรายชื่อ User จาก Group
GetMemberOf	อ่านรายชื่อ Group จาก User
GetRule	อ่าน กฎ ที่มีอยู่
SetDeleteRule	ลบ กฎ ที่ต้องการลบ
SetNewLog	สร้าง Log
SetNewRule	สร้างกฎ

ตารางที่ 6-3 รายละเอียดการทำงานของฟังก์ชันใน ADConnect

6.3.3 เฟอร์ชันนอลไฟร์วอลล์ (Personal Firewall)

เฟอร์ชันนอลไฟร์วอลล์จะแบ่งการทำงานออกเป็น 2 ส่วน คือ

1. ไฟร์วอลล์
2. ระบบตรวจจับผู้บุกรุกทางเครือข่ายคอมพิวเตอร์

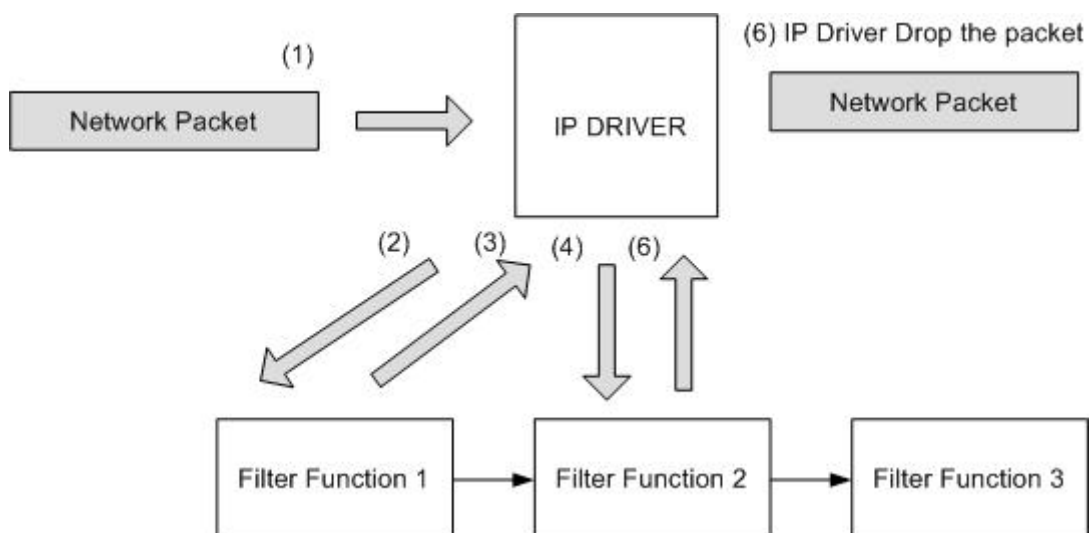


รูปที่ 6-4 แสดงส่วนประกอบเฟอร์ชันนอลไฟร์วอลล์

6.3.3.1 แพ็กเก็ตฟิลเตอร์ริงไฟร์วอลล์บนวินโดวส์ 2000

ไฟร์วอลล์ที่พัฒนาเป็นแบบ แพ็กเก็ตฟิลเตอร์ริง (Packet Filtering) ซึ่งจะสามารถใช้ฟังก์ชันฟิลเตอร์เพียงทีละฟังก์ชันเท่านั้น ดังนั้นหากโปรแกรมหนึ่งเรียกใช้ไคร์เวอร์ไฟร์วอลล์อยู่โดยส่งฟังก์ชันฟิลเตอร์เข้าไป ไคร์เวอร์ไฟร์วอลล์จะไม่สามารถถูกใช้ได้อีกในขณะนั้น แต่เราสามารถแก้ปัญหานี้ได้ โดยการกำหนดลำดับของฟิลเตอร์ฟังก์ชัน แล้วให้ระบบเรียกฟังก์ชันฟิลเตอร์เข้าไปทำงานทีละฟังก์ชันตามลำดับ จนกว่าจะมีฟังก์ชันใดฟังก์ชันหนึ่งส่งค่ากลับเป็น “DROP PACKET” ถ้าฟังก์ชันทั้งหมดส่งค่ากลับเป็น “ALLOW PACKET” แพ็กเกจเหล่านั้น จะถูกอนุญาตให้ผ่านไป

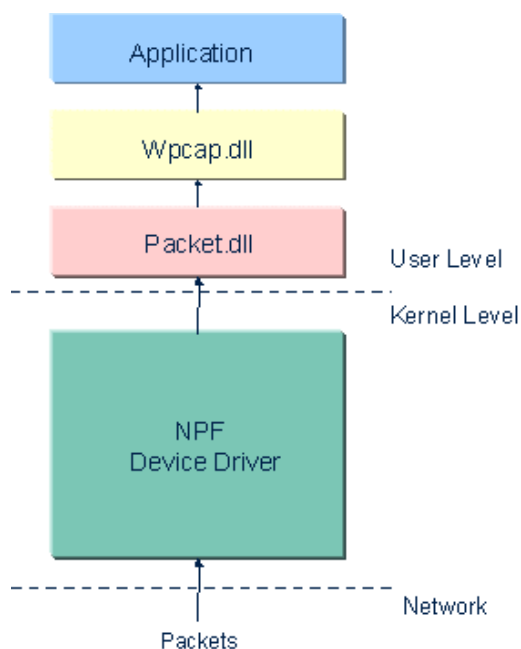
เมื่อเครื่องได้รับแพ็กเก็ตเข้ามา โดยที่ IP Driver มีฟังก์ชันฟิลเตอร์อยู่ตามที่กำหนดไว้ IP Driver จะส่งแพ็กเกจนั้นเข้าไปโดย ผ่านเข้าไปยังฟังก์ชันฟิลเตอร์ตามลำดับไปเรื่อยๆ โดยรอค่าที่ส่งกลับออกมาสมมุติฟังก์ชันแรกส่งค่ากลับเป็น “ALLOW PACKET” เมื่อ IP DRIVER ได้รับค่าส่งกลับจากฟังก์ชันแรกเป็น “ALLOW PACKET” ดังนั้น IP DRIVER จะส่งแพ็กเกจนั้นไปที่ฟังก์ชันที่สองต่อไป ในกรณีนี้สมมุติให้ฟังก์ชันที่สองนี้ส่งค่ากลับเป็น “DROP PACKET” เมื่อ IP DRIVER ได้รับค่าส่งกลับจากฟังก์ชันที่สองเป็น “DROP PACKET” ดังนั้น IP DRIVER จะไม่ส่งแพ็กเกจนี้ต่อไปยังระบบ และจะไม่ส่งไปยังฟังก์ชันต่อไปอีก



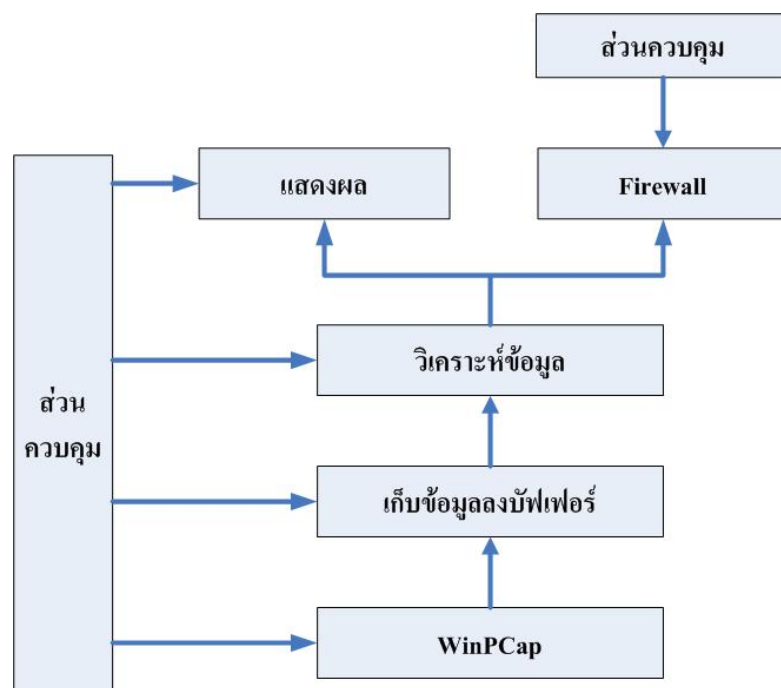
รูปที่ 6-5 แสดงขั้นตอนการทำงานของไฟร์วอลล์

6.3.3.2 ระบบตรวจจับผู้บุกรุกทางเครือข่ายคอมพิวเตอร์

ระบบตรวจจับผู้บุกรุกทางเครือข่ายคอมพิวเตอร์ จะอาศัยคุณสมบัติ และ ความสามารถของ WinPCap ซึ่งเป็นไลบรารีที่ทำการติดต่อกับการ์ดแลน เพื่อทำการควบคุมการทำงานของ การ์ดแลนและตรวจจับแพ็กเก็ต เพื่อนำวิเคราะห์

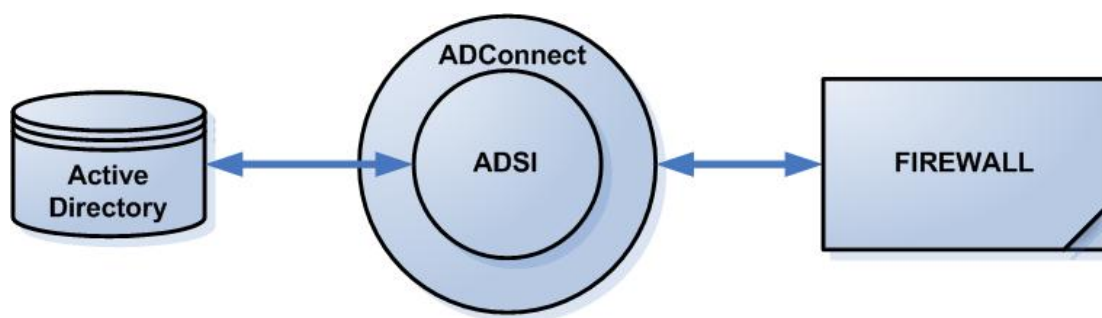


รูปที่ 6-6 แสดงระดับชั้นการทำงานของ WinPCap



รูปที่ 6-7 โครงสร้างของระบบตรวจจับผู้บุกรุกทำงานร่วมกับไฟร์วอลล์

เนื่องจากเพอร์ซันนอลไฟร์วอลล์ (Personal Firewall) จะมีความสามารถในการที่จะรับกฎ เพื่อเริ่มการทำงานของไฟร์วอลล์ จากเครื่องเซิร์ฟเวอร์ และ จะมีการส่งล็อกไฟร์ไปเก็บไว้ยัง ศูนย์กลางเมื่อมีการตรวจพบการโจมตี หรือ มีสิ่งผิดปกติเกิดขึ้น ซึ่งโครงสร้างการทำงานของส่วนที่ใช้ในการติดต่อกับเครื่องเซิร์ฟเวอร์ แสดงดังรูปที่ 6-6 โดย เพอร์ซันนอลไฟร์วอลล์จะมีการติดต่อ ไปยังเซิร์ฟเวอร์โดยผ่านคลาส (Class) ADConnect ที่สร้างขึ้น



รูปที่ 6-8 แสดงโครงสร้างส่วนติดต่อกับเซิร์ฟเวอร์

เพอร์ซันนอลไฟร์วอลล์จะติดตั้งอยู่ที่เครื่องลูกข่ายทุกเครื่องในระบบ โดยมีหน้าที่การทำงานดังนี้

- เป็นไฟร์วอลล์ชนิดแพ็กเก็ตฟิลเตอร์ริง (Packet Filtering Firewall)

- ตรวจจับผู้บุกรุกทางเครือข่ายที่เข้ามาที่เครื่องลูกข่าย รวมทั้งสิ่งผิดปกติที่ไม่เป็นไปตามมาตรฐานของ โพรโทคอลทีซีพี (TCP) , ยูดีพี(UDP), ไอพี(IP), ไอซีเอ็มพี(ICMP)
- ส่งการแจ้งเตือนกลับไปยังล็อกมอนิเตอร์เมื่อตรวจจับได้ว่าการบุกรุกเกิดขึ้น

ขอบเขตและความสามารถ

ในระบบจะมีเครื่องลูกข่ายหลายเครื่องโดยทุกเครื่องจะมีการติดตั้ง เพอร์ซันนอลไฟร์วอลล์ ซึ่งก็คือเอนต์ที่ฝังตัวทำงานอยู่แบบอัตโนมัติ โดยจะมีการควบคุมดูแลจากส่วนกลางโดยผู้ใช้งาน ไม่รับรู้ถึงการทำงานของเอนต์ รวมไปถึงผู้ดูแลระบบสามารถกำหนดกฎการป้องกันการบุกรุกให้ผู้ใช้ในแต่ละกลุ่มตามความเหมาะสม

อีกทั้งยังมีส่วนของการทำงานที่เป็นระบบตรวจจับผู้บุกรุกที่คอยทำหน้าที่ตรวจสอบว่ามีการบุกรุกเข้ามาที่เครื่องลูกข่ายนั้นๆหรือไม่ ถ้าจะมีการแจ้งเตือนไปยังเครื่องเซิร์ฟเวอร์กลางเพื่อนำผลที่ได้ไปวิเคราะห์หาแนวทางป้องกันต่อไป

6.3.4 ไฟร์วอลล์แอดมินนิสเตรเตอร์ (Firewall Administrator)

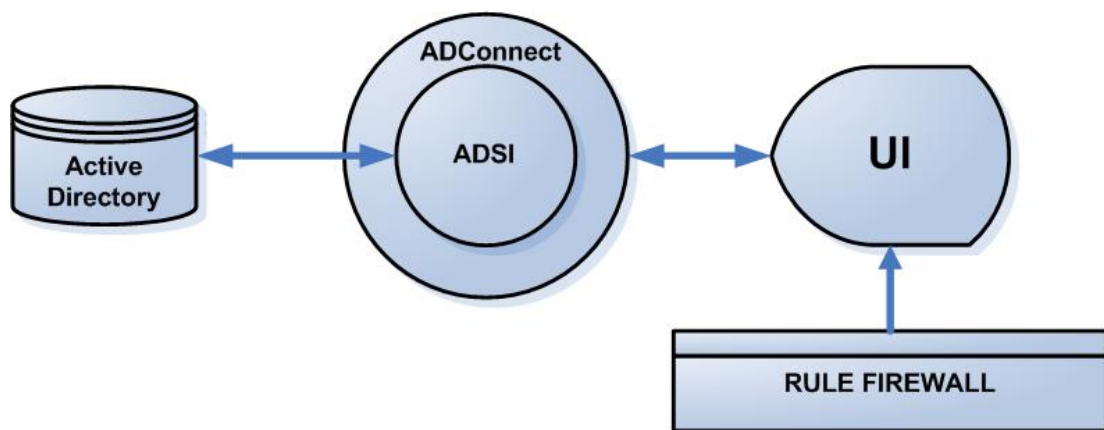
เป็นส่วนที่มีความสำคัญในระบบเพื่อกำหนดกฎของไฟร์วอลล์ และทำงานกับ Active Directory Service เพื่อให้มีการเข้าถึงได้จากเครื่องลูกข่ายเพื่อนำกฎไปใช้ในการป้องกันการบุกรุกโดยข้อมูลกฎจะเก็บอยู่ใน Active Directory Database

ขอบเขตและความสามารถ

- สามารถพิสูจน์ผู้ใช้ที่มาขอใช้ทรัพยากรได้อย่างถูกต้องโดยใช้ความสามารถของแอ็กทีฟไดเรกทอรี
- สามารถกระจายกฎและจัดเก็บได้อย่างมีระเบียบ
- สามารถตรวจสอบได้ว่าเครื่องลูกข่ายยังติดต่อยู่ในระบบหรือไม่

การทำงาน

เมื่อเปิดโปรแกรม Administration firewall จะทำการอ่านข้อมูลผ่าน ADConnect เพื่อเข้าถึงข้อมูลที่อยู่ใน Active Directory Service โดยจะเลือกแสดงตามกลุ่มผู้ใช้ที่ถูกเลือก และเมื่อมีการ เพิ่ม ลด และแก้ไข ข้อมูลกฎที่อยู่ในดาต้าเบส ดังรูปที่ 6-9 จะมีส่วนแสดงการทำงานของโปรแกรมไฟร์วอลล์แอดมินนิสเตรชัน (Firewall Administration)



รูปที่ 6-9 แสดงโครงสร้างการทำงานของไฟร์วอลล์แอดมินิสเทรชัน

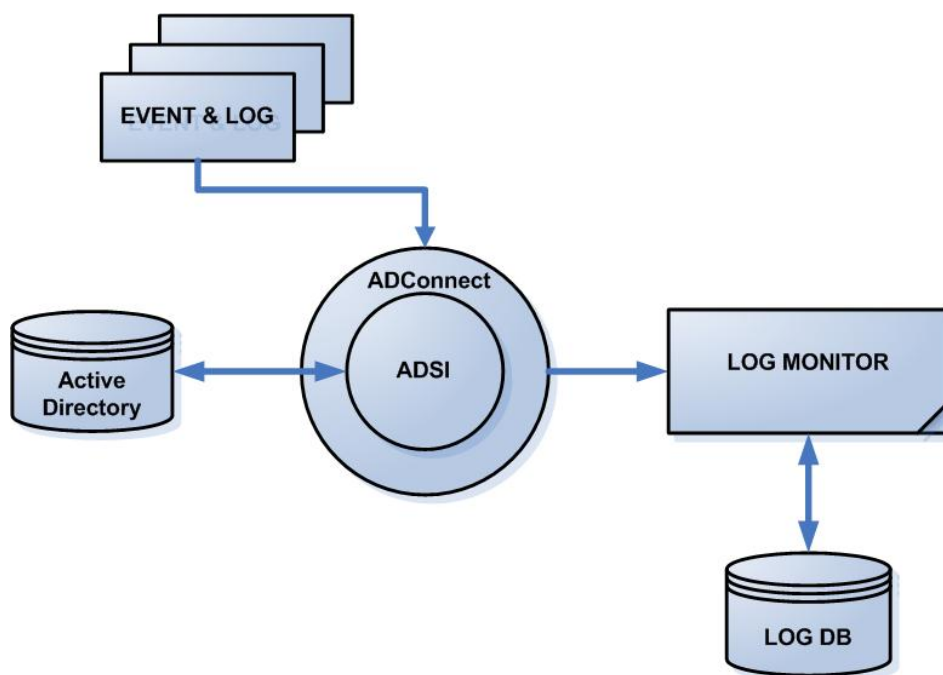
6.3.5 ล็อกมอนิเตอร์ (Log Monitor)

ในระบบการใช้จริงจะมีเครื่องลูกข่ายในระบบจำนวนมาก ซึ่งอาจจะมีการบุกรุกที่มากมายตามมาด้วย เมื่อเอเจนต์ที่อยู่ในเครื่องลูกข่ายตรวจพบการบุกรุก รวมทั้งการโจมตีจะแสดงรายละเอียด รวมทั้งจะส่งข้อมูลมาที่เครื่องล็อกมอนิเตอร์ เพื่อแสดงรายละเอียดและเก็บลงฐานข้อมูล เพื่อให้ผู้ดูแลระบบสามารถตรวจสอบและวิเคราะห์หาแนวทางการป้องกันที่เหมาะสมได้ต่อไป

ขอบเขตและความสามารถ

ล็อกมอนิเตอร์จะติดตั้งอยู่บนเครื่องที่เป็นโดเมนอื่นที่ไม่ใช่โดเมนหลัก หรือ เครื่องโดเมนหลักที่ติดตั้งไฟร์วอลล์ Administration ทำหน้าที่รองรับรายละเอียดการบุกรุกจากเครื่องลูกข่าย และแสดงผลรายละเอียดที่มีอยู่ในฐานข้อมูล

การทำงานติดต่อทุกอย่างในระบบไฟร์วอลล์จะทำงานอยู่บนความสามารถของบริการ Active directory ของ windows 2000 โดยข้อมูลจะเก็บอยู่ใน Active Directory Database และเข้าถึงข้อมูลผ่าน ADSI ไปยัง Active Directory Service เพื่อเข้าถึงข้อมูลที่จัดเก็บ ซึ่งการทำงานของล็อกมอนิเตอร์ที่ทำงานร่วมกันกับ แอ็กทีฟไดเรกทอรี (Active Directory) แสดงโครงสร้างการทำงาน ดังรูปที่ 6-7



รูปที่ 6-10 แสดงโครงสร้างการทำงานระหว่างล็อกมอนิเตอร์กับแอคทีฟไดเรคทอรี

โดยที่โครงสร้างของตารางที่ใช้ในการเก็บข้อมูลการโจมตีต่าง ๆ แสดงดังรูปที่ 6-8 ซึ่งมีรายละเอียดให้การเก็บข้อมูลดังนี้

- LogNo เป็นข้อมูลชนิด Number และ เป็นคีย์หลัก แสดงลำดับที่ของ ล็อก
- AttackDst เป็นข้อมูลชนิด Text ใช้เพื่อเก็บหมายเลข ไอพีปลายทาง
- AttackSrc เป็นข้อมูลชนิด Text ใช้เพื่อเก็บหมายเลขไอพีต้นทาง
- AttackType เป็นข้อมูลชนิด Text ใช้เพื่อเก็บชนิดหรือ ประเภทการโจมตี
- AttackDate เป็นข้อมูลชนิด Text ใช้เก็บวันที่มีการเก็บล็อกการโจมตีนั้น ๆ
- AttackTime เป็นข้อมูลชนิด Text ใช้เก็บเวลาที่มีการเก็บล็อกฐานข้อมูล
- User เป็นข้อมูลชนิด Text ใช้เพื่อเก็บชื่อ User ที่แจ้งล็อกมายังเซิร์ฟเวอร์
- Group เป็นข้อมูลชนิด Text ใช้เพื่อเก็บ Group ของผู้ใช้ที่แจ้งล็อกมายังเซิร์ฟเวอร์

ชื่อเขตข้อมูล	ชนิดข้อมูล	คำอธิบาย
LogNo (กี๊ย์หลัก)	Number	หมายเลขลำดับที่ของล็อก
AttackDst	Text	หมายเลขไอพีปลายทาง
AttackSrc	Text	หมายเลขไอพีต้นทาง
AttackType	Text	ชนิดของการโจมตี
AttackDate	Text	วันที่
AttackTime	Text	เวลา
User	Text	ชื่อผู้ใช้
Group	Text	กลุ่มผู้ใช้

ตารางที่ 6-4 แสดงโครงสร้างตารางที่ใช้ในการเก็บล็อก